ASSIGNMENT

Introduction to Network Security and Cryptography in Network Security
Cryptography and Network Security

Q1. Define network security and explain its fundamental principles and objectives.

Network security is the practice of protecting computer networks, connected devices, applications and transmitted information from unauthorized access, misuse, modification, disruption and destruction. It combines policies, technologies, procedures and monitoring to keep network services reliable and information protected.

Confidentiality: Information should be accessible only to authorized people or systems. Encryption, access controls and secure authentication help maintain confidentiality. **Integrity:** Data should remain accurate and complete and should not be changed without permission. Hashes, message authentication codes, digital signatures and access controls help protect integrity. **Availability:** Networks and services should remain accessible when required. Backups, redundancy, patching, capacity planning and denial-of-service protection support availability.

Authentication: Verifies the identity of a user, device or service. Passwords, multi-factor authentication, certificates and security keys are common methods. **Authorization:** Determines what an authenticated identity is allowed to do. Role-based permissions and least-privilege access help prevent users from accessing resources beyond their responsibilities.

```
User / Device → Authentication → Authorization check → Permitted network resource
Confidentiality + Integrity + Availability protect the data and service throughout
```

Q2. Explain the threat landscape in network security, types of attacks and vulnerabilities, examples and preventive measures.

The network threat landscape includes malicious people, compromised devices, software weaknesses, insecure configurations and human mistakes. Threats may come from outside an organization or from insiders who misuse legitimate access. A vulnerability is a weakness; a threat is a possible cause of harm; and an attack is an attempt to exploit a weakness.

Malware: Viruses, worms, trojans and ransomware can damage systems, steal information or interrupt services. Prevention includes endpoint protection, secure backups, software updates and careful handling of attachments. **Phishing and social engineering:** Attackers trick users into revealing credentials or opening harmful links. Awareness training, email filtering and multi-factor authentication reduce risk.

Denial-of-service (DoS/DDoS): An attacker overwhelms a service with traffic or requests, making it unavailable. Rate limiting, traffic filtering, resilient infrastructure and DDoS mitigation services help. **Man-in-the-middle:** An attacker secretly intercepts or alters communication. Proper TLS certificate validation, secure Wi-Fi and strong encryption help prevent it.

Packet sniffing: Unprotected traffic may be captured and read. Use encrypted protocols such as HTTPS, SSH and VPNs. **Spoofing:** An attacker forges an address or identity, such as an IP or DNS identity. Network filtering, authentication and secure DNS practices reduce risk. **Password and brute-force attacks:** Repeated guesses target weak credentials. Use long unique passwords, rate limits, MFA and account monitoring.

Common vulnerabilities include unpatched software, default passwords, unnecessary open ports, weak encryption, misconfigured firewalls, insecure wireless networks, excessive privileges and exposed services. Preventive measures include regular patching, vulnerability assessment by authorized staff, secure configuration, network segmentation, firewalls, intrusion detection, logging, backups and incident-response planning.

Q3. Discuss legal and ethical considerations in network security.

Network security work must follow applicable laws, organizational policies and ethical standards. Security professionals should protect personal and confidential information, collect only the data needed for a legitimate purpose, store it securely and limit access to authorized people. Data should not be disclosed or used for unrelated purposes.

Responsible security testing: Penetration testing, scanning and vulnerability research must be performed only with clear written permission and a defined scope. Testing should avoid unnecessary disruption, protect any data

encountered and report findings responsibly to the system owner. Accessing another person's account, device or network without permission is unethical and may be unlawful.

Authorized access: Users and administrators should use only the systems and information for which they have permission. Organizations should apply least privilege, maintain audit logs and promptly remove access when it is no longer required. **Legal compliance:** Organizations must follow applicable cybersecurity, privacy, data-protection and sector-specific rules in the jurisdictions where they operate. In India, relevant requirements may include the Information Technology Act, 2000, rules and directions issued under it, and the Digital Personal Data Protection Act, 2023, as applicable and in force.

Ethical practice includes honesty, confidentiality, competence, avoiding harm, documenting work accurately and disclosing vulnerabilities through responsible channels. A security professional should never use technical ability as permission to access systems without authorization.

Q4. Explain the role of cryptography in securing network communications. Describe SSL/TLS and IPsec.

Cryptography protects network communication by transforming readable information into protected forms and by providing ways to verify identity and detect tampering. Encryption provides confidentiality; message authentication codes and digital signatures provide integrity and authentication; and certificates help establish trust in public keys.

SSL/TLS: SSL was an earlier protocol family and is obsolete. TLS (Transport Layer Security) is its modern successor. TLS protects application traffic, for example HTTPS between a browser and a website. During the handshake, the parties negotiate protocol parameters, authenticate the server using its certificate, and establish shared session keys using a key-exchange method. The application data is then protected using symmetric authenticated encryption. TLS helps provide confidentiality, integrity and server authentication; mutual TLS can also authenticate clients.

```
Client ↔ TLS handshake (certificate validation and session-key establishment) ↔ Server
      Then: encrypted and integrity-protected application data in both directions
```

IPsec: Internet Protocol Security is a suite of protocols that protects IP packets at the network layer. It is commonly used to build VPNs. Its main protection protocols are Authentication Header (AH), which provides integrity and origin authentication but not encryption, and Encapsulating Security Payload (ESP), which can provide confidentiality, integrity and authentication. IPsec can operate in transport mode, protecting the payload of an IP packet, or tunnel mode, protecting an entire inner IP packet inside a new packet. Internet Key Exchange (IKE) negotiates security associations and keys.

TLS commonly protects individual application connections, while IPsec can protect IP traffic between hosts or networks. Both rely on correct configuration, secure algorithms, key management and certificate or peer authentication.

Q5. What is PKI? Explain its components and working, including digital certificates and Certificate Authorities.

Public Key Infrastructure (PKI) is a framework of people, policies, hardware, software and procedures used to create, distribute, manage, validate and revoke public-key digital certificates. PKI helps users trust that a public key belongs to a particular person, organization or server.

Components: (1) **Certificate Authority (CA):** A trusted organization that verifies identity according to its rules and digitally signs certificates. (2) **Registration Authority (RA):** Performs or supports identity checks before a certificate is issued. (3) **Digital certificate:** A signed electronic document that binds an identity to a public key and includes information such as issuer, validity period, subject and key usage. (4) **Certificate repository:** Makes certificates and related information available. (5) **Revocation mechanisms:** Certificate Revocation Lists (CRLs) and Online Certificate Status Protocol (OCSP) can communicate whether a certificate has been revoked. (6) **End entities:** Users, devices or servers that hold and use certificates and corresponding private keys.

Working: First, an applicant generates a public/private key pair and submits a certificate request. The CA or RA verifies the applicant's identity. The CA then issues a certificate by digitally signing the certificate data. A relying party receives the certificate and checks the CA's signature, certificate chain, validity dates, intended use and revocation status. If these checks succeed and the certificate name matches the service, the relying party can trust the public key for the stated purpose.

```
Applicant generates key pair → Identity verification by RA/CA → CA signs certificate →
                                Certificate delivered
Relying party validates chain, name, validity and status → Uses authenticated public key
```

Role in secure communication: In HTTPS, a website presents a certificate containing its public key. The browser validates the certificate chain to a trusted root CA and checks the website name and validity. The TLS handshake then uses authenticated key establishment to create session keys. The private key corresponding to the certificate must remain protected. PKI therefore supports trust, authentication and secure key establishment across networks.